

Security Thinking



S1 - The Extended CIA Model & Five-Layer Framework

Learning Outcomes



LO1

Evaluate a range of encryption and authentication methods for a given set of requirements

LO2

Evaluate different approaches to assessing a system's security and use these to evaluate the security of a system - This Session

LO3

Utilise systematic knowledge to create secure environments at the host or network level

LO4

Develop and evaluate software that addresses the most common and most severe security concerns

This session addresses LO2. All four learning outcomes are assessed through the coursework.



Block 1 - Mental Model

Sessions 1 and 2 - the foundation every defence in this module rests on



What This Session Establishes



Today you build the vocabulary the whole module - and your coursework - depends on

- **Name all five security properties and state what each one protects against**
- **Map a real breach across all five properties - including the two CIA alone misses**
- **Describe the five-layer security framework and how it structures the coursework**
- **Identify your assigned coursework domain - this stays with you for all 12 sessions**

Different Backgrounds, Different Strengths



- **This cohort brings Software Engineering, UI/UX, and DevOps experience. That is a feature, not a problem.**
- Different backgrounds lead in different sessions - no single background is advantaged throughout the module.
- Today everyone is on equal footing. This session is vocabulary and systems thinking - no coding required.

Who typically leads where:

- UI/UX students: threat modelling, trust boundaries, report writing (S1, S2, S12)
- DevOps students: infrastructure, configuration, pipelines (S7, S10)
- Software Engineering students: code critique, application security (S4, S6)

KEY CONCEPT



A system can satisfy CIA and still be impersonatable - and leave no trace of who acted

The classic triad answers three questions: is the data protected? Is it intact? Is the system reachable? It does not ask: is this entity genuinely who it claims to be? And: can we prove who did what, and when? Without Authenticity and Accountability, those questions have no answer in the system.



Confidentiality and Integrity



Confidentiality

Information is accessible only to those authorised

Fails when: a database is exfiltrated

Integrity

Information and systems are accurate and unaltered

Fails when: records are silently modified without detection

Analogy

A sealed envelope (Confidentiality) - only the addressee opens it. A tamper-evident seal (Integrity) - you can tell if anyone opened it en route. A broken seal means Integrity failed, even if the contents look untouched.

Properties 1 and 2 of 5 - from the classic CIA triad

Availability



Availability

Systems and data are accessible when needed

Fails when: a service is disrupted or rendered unreachable

Real-world example

A hospital's patient record system goes offline during an emergency. The data is secure and intact - but entirely useless.

Analogy

A fire exit. It must be accessible precisely when you need it most - not just on normal days. A locked fire exit during an emergency is not a fire exit. Availability is exactly the same principle.

Property 3 of 5 - completes the classic CIA triad

Authenticity - The Extended Model

Authenticity

An entity or message is genuinely what it claims to be

Fails when: an impersonator gains access, or traffic is intercepted by a false endpoint

Why CIA misses this

CIA confirms the data is protected, intact, and reachable. It says nothing about whether the entity holding the key is who they claim to be.

Analogy

A photo-ID check at the entrance. The vault can be locked (Confidentiality), its contents untouched (Integrity), and open for business (Availability) - but if anyone can claim to be the key-holder, the vault is useless.

Property 4 of 5 - the first gap CIA does not cover

Accountability - The Second Gap



Accountability

Every action can be traced to a responsible party; actions cannot be denied

Fails when: no audit trail exists, or shared credentials make attribution impossible

Real-world example

A shared admin account performs a destructive action. No one can determine who did it, when, or whether it was authorised.

Analogy

A sign-in logbook with timestamps. If multiple people share one key and something goes missing, no one can be held responsible. The logbook makes Accountability possible. Without it, the property simply does not exist.

Property 5 of 5 - the second gap CIA does not cover

The Five Security Properties

The Classic Triad (CIA)

Confidentiality

Information accessible only to authorised parties

Integrity

Information accurate and unaltered

Availability

Systems accessible when needed

Extended - What CIA Misses

Authenticity

An entity or message is genuinely what it claims to be

Accountability

Every action traced to a responsible party; actions cannot be denied

Every mechanism, control, and SRS requirement in this module maps to at least one of these five properties

What Failure Looks Like - One Statement Per Property



Confidentiality fails - a database is exfiltrated

Integrity fails - records are silently altered without detection

Availability fails - a service goes down under a denial-of-service attack

Authenticity fails - a user logs in as someone else, or traffic is intercepted by an impersonator the system trusts

Accountability fails - a privileged action is taken and no one can determine who did it, or when, or whether it was authorised

KEY CONCEPT



**Integrity says the message has not changed.
Authenticity says it came from the right
source.**

Both can be true. Either can fail independently. A message can arrive intact and unmodified - from an attacker posing as your bank. A message can arrive from a verified sender - with its contents corrupted in transit. These are different properties requiring different controls.

Equifax 2017 - A Breach Through All Five Lenses



147 million records | Unpatched Apache Struts CVE | 78-day dwell time before detection

Confidentiality failed - personal and financial records accessed without authorisation

Integrity failed - with 78 days of undetected access, the integrity of records could not be confirmed or assured

Availability failed - services were disrupted during the response period

Authenticity failed - the attacker moved through systems as if authorised, unchallenged by identity controls

Accountability failed - 78 days of undetected activity; actions could not be traced or attributed in real time

The CIA Gap in the Equifax Breach

What CIA identifies

Confidentiality failure

Records accessed without authorisation - a textbook confidentiality breach

Integrity failure

78 days of undetected access meant the integrity of records could not be confirmed

Availability failure

Service disruption during the response and remediation period

What CIA misses

Authenticity failure

The attacker moved as a trusted entity. CIA does not ask: is this entity who it claims to be?

Accountability failure

78 days of undetected activity. CIA does not require that actions be traceable to an individual in real time.

Security Failures Are Systemic - Not Purely Technical



- **Most real breaches violate more than one property simultaneously**
- Equifax: technology failure (unpatched CVE), process failure (no patch management cycle), detection failure (78-day blind spot)
- **Security is always a people, process, and technology problem together - never purely technical**
- The five-property model captures all three dimensions

Designing for security means designing for all five properties - and for the people, processes, and technologies that either uphold or undermine them.



The Five-Layer Framework

The structural skeleton of the module and the coursework



Layer 1 - Identity and Access Management (IAM)

Scope: who is allowed in, and what are they allowed to do?

Covers: authentication, authorisation, role assignments, credentials, secrets management

Example SRS requirements

IAM-01: all admin accounts require MFA

IAM-02: role-based access control (RBAC) for all user roles

Analogy

IAM is the reception desk and key-card system combined. It decides who gets a badge (authentication), which doors that badge opens (authorisation), and revokes access the moment someone leaves. Without IAM, anyone can be anyone.

Connects to: Authenticity (are you who you claim?) and Accountability (can we trace what you did?)

Layers 2 and 3 - Network and System

Layer 2 - Network

Controls what enters and leaves the environment

Firewalls, DMZ, WAF, rate limiting, micro-segmentation

Example SRS requirements

NET-01: no public-facing database endpoint

NET-02: WAF and rate limits on all public endpoints

NET-03: network micro-segmentation between zones

Layer 3 - System

Controls the platform itself

OS hardening, patch management, CIS benchmarks, minimal installed software

Example SRS requirement

SYS-01: OS images built to CIS benchmark baseline; patching within 30 days of release

Layers 4 and 5 - Application and Data

Layer 4 - Application

Controls the code running on the system

Input validation, output encoding, secrets management

Example SRS requirements

APP-01: all input validated; all output encoded

APP-02: secrets retrieved from vault at runtime, never hardcoded

Layer 5 - Data

Protects the information itself

Encryption at rest and in transit, key management, backup and recovery

Example SRS requirements

DATA-01: all PII encrypted at rest (AES-256)

DATA-02: encryption key rotation on schedule

DATA-03: backup schedule with tested restore procedures

The Five Layers Are the Coursework Skeleton



- **Every SRS requirement in Part A maps to one of the five layers**
- Every Part B section (B2-B8) corresponds to one or more layers - the layer is the unit of evaluation
- Every finding you write belongs to a layer and violates at least one property
- **Your task in the coursework is to evaluate whether a real system has effective controls at each layer**

You do not build a system. You evaluate one. The five layers tell you what to look for, where to look, and how to structure what you find.

Your Coursework Domain - student index mod 6

0 Banking and Financial Services

1 Healthcare

2 Transportation and Aviation

3 Education

4 Ecommerce and Retail

5 Hospitality

How to find your domain

Take your NIBM student index number. Divide by 6 and keep the remainder (0-5).

Your domain is fixed from today. All 12 sessions and your full coursework are written for this domain.

The assets, threats, and controls in your domain shape every piece of work you produce in this module

Activity - Breach Case Study

1. Read the provided breach narrative
2. Map the failure to all five properties - not just CIA
3. Identify which properties were designed for and which were neglected
4. Identify the layer(s) at which the failure occurred
5. Name your domain and list 3 critical assets per layer for a system in that domain

45 minutes

Work in pairs

Use the demo alongside this activity

Open Demo_PropertyMapper.html and select consequences to watch properties light up in real time.

Lab - CVE Deep Dive

1. Go to cve.org or nvd.nist.gov
2. Find one recent high-severity CVE in your assigned domain
3. Map it to the violated property from the extended model
4. Does it violate Authenticity or Accountability - or only the classic three?
5. Write five structured lines: CVE ID | what failed | impact | layer | property | CIA alone?

45 minutes

Individual - browser only

Output template

CVE ID:

What failed:

Impact:

Layer:

Property:

CIA alone?

Interactive Demo - Breach to 5-Property Mapper

File: NB5004CEM_S1_SecurityThinking_Demo_PropertyMapper.html | Open in any browser, no install required

- **What to try**
- Select a breach consequence from the left panel
- Watch which of the five properties light up on the right - and which remain dim
- The bottom banner tracks what CIA alone catches versus what the extended model catches in real time
- **Key question: can you find a consequence where Authenticity or Accountability catches something CIA alone does not?**

Use this alongside the activity worksheet. Open it on your personal device now - no setup required.

Coursework Con - What You Can Write After Today

Part A (30%) and Part B (60%) both require today's vocabulary from the very first sentence

- **A1 - System context and assets**
 - You can name what you are protecting (assets), why it matters (which property), and where it sits (which layer)
- **A3 - Key risks**
 - You can articulate which property each threat targets - not just "data breach" but "Confidentiality failure at the Data layer"
- **B1 - Target environment (Part B)**
 - You know the five-layer framework. Part B uses it as the evaluation structure across all sections B2-B8

Lab output from today = the start of your CVE evidence log. Keep these structured notes - they count towards Part B.

Questions & Discussion



S1 - Security Thinking: The Extended CIA Model and Five-Layer Framework



Disclaimer and Copyrights



The information presented in this presentation is intended for general informational purposes only. It is not meant to be comprehensive or to constitute professional advice. Any reliance you place on such information is strictly at your own risk. While I strive to keep the information accurate and up-to-date, I make no representations or warranties of any kind, express or implied, about the completeness, accuracy, reliability, suitability, or availability concerning the content within this presentation.

This presentation may include references or links to third-party websites or content. I do not endorse the views expressed or the information provided on such external sites. I am not responsible for the content of any linked site or any link contained in a linked site.

Any action you take upon the information presented in this presentation is strictly at your own discretion. I will not be liable for any losses or damages in connection with the use of this information.

This disclaimer is subject to change without notice.

@ Images and artworks used in this presentation are used for general informational purposes only. It may contain copyrighted material, the use of which may not have been specifically authorised by the copyright owner. This material is available in an effort to explain issues relevant to the topic and should constitute fair use.

Last modified: 19 Jun 2026